

III.C.3(a) *Protecting Sensitive Customer Information*

The Information Security Standards require management to develop, and the board to approve, an information security program to protect the security and confidentiality of customer information. This program may be a component of the institution's overall information security program.

The institution should protect customer information from threats to security or integrity. The institution should also protect customer information from unauthorized access or use that would result in substantial harm or inconvenience to any customer. The board should also annually review a written report, prepared by management, regarding the financial institution's actions toward GLBA compliance.

III.C.3(b) *Cybersecurity*

Institutions should take a comprehensive approach to maintain the security and resilience of their IT infrastructure, including the establishment of cybersecurity controls. Although an institution is not required to have a separate cybersecurity policy or program, its information security program should identify, measure, mitigate, monitor, and report on the heightened risks associated with cybersecurity. To address cybersecurity risk, the information security program should consider the following:

- Cyber risk management and oversight.
- Threat intelligence and collaboration.
- Cybersecurity controls.
- External dependency management.
- Cyber incident management and resilience.

Additional information on these topics is available in the FFIEC Cybersecurity Assessment Tool.²¹

III.C.4 *Business Continuity*

The board should approve policies, while senior management should establish and implement policies, procedures, and responsibilities for the enterprise-wide business continuity program. The board should annually approve the institution's business continuity program. Management should document, maintain, and test the plans and backup systems periodically to mitigate the consequences of system interruptions, natural and other disasters, and unauthorized intrusions that could result in the loss, damage, or degradation of data, systems, or services. Management should also provide to the board on an annual basis a written report on the overall status of the business continuity program and the results of testing of the plan and backup systems. Refer to the *IT Handbook's* "Business Continuity Planning" booklet for more information.

²¹ Refer to the [FFIEC Cybersecurity Assessment Tool](#), June 2015. Use of the Cybersecurity Assessment Tool by institutions is optional.

III.C.5 Software Development and Acquisition

Management should assess and mitigate operational risks associated with the development or acquisition of software. Management should develop applicable policies that specify risk management controls for the development and acquisition of systems. Management should guide the development or acquisition of software by using a system development life cycle (SDLC) or similar methodology appropriate for the specific IT environment. The extent or use of the SDLC depends on the size and complexity of the institution and the type of development activities performed. If the institution primarily acquires software, management should verify the effective use of an SDLC by the third-party provider.

Each phase of the SDLC should have procedures that verify the maintenance and integrity of controls before the start of the next phase. When identifying the controls to be implemented in each phase, the institution should incorporate the fundamental principles of confidentiality, integrity, and availability. Audit should review the SDLC to ensure that appropriate controls are incorporated during development. Management should analyze the operational impact early in the process to identify any additional cost and support issues.

Management should test new technology, systems, and products thoroughly before deployment. Testing, which should include tests of security, validates that equipment and systems function properly and produce the desired results. As part of the testing process, management should verify whether new technology systems operate effectively with other technology components, including vendor-supplied technology. Pilot programs or prototypes can be helpful in developing new technology before management accepts the technology for use on a broad scale. Management should conduct retesting periodically to help manage risk exposure on an ongoing basis.

Institutions that outsource the development of software should have a process to review their third-party provider's control environment, reputation, and capabilities. Institutions often employ structured acquisition methodologies similar to the SDLC when acquiring significant hardware and software products.

Refer to the *IT Handbook's* "Development and Acquisition" booklet for more information.

III.C.6 IT Operations

Management should be aware of and mitigate risks associated with IT operations. The institution and its service providers may have one or more IT operations groups. The number and types vary across institutions. Common examples of IT operations are data center or computer operations, network services, distributed computing, personal or desktop computing, change management, project management, security, resource management, and contingency and resiliency planning.

Many operations functions have significant risk factors that should be addressed through effective management and control. Rapidly evolving threats require an effective monitoring and response program to ensure that vulnerability remediation occurs in a timely manner. Ongoing

business-driven changes to applications should have effective change control programs to ensure that application updates are implemented in a timely manner. The institution should have controls over systems changes, including the following:

- Testing, authorization, and approval.
- Timing of implementation.
- Post-implementation review.
- Rollback or recovery of systems when changes are unsuccessful.

Refer to the *IT Handbook's* "Operations" booklet for more information.

III.C.7 Insurance

The institution may rely on insurance policies as part of a mitigation strategy. Traditional business insurance policies include coverage for errors and omissions, commercial general liability, and directors' and officers' liability policies. Management should understand the institution's insurance needs and the limitations of insurance coverage. These policies generally exclude, or may not include, liability for all areas of IT operations and cybersecurity.

In establishing an insurance program, management should recognize its exposure to loss, the extent to which insurance is available to cover potential losses related to information assets and technology, and the cost of such insurance. The insurance program should be commensurate with the size, complexity, and risk of the institution. Management should weigh these factors to determine how much risk the institution assumes directly. In assessing the extent of that residual risk, the institution should analyze the potential effect of an uninsured loss on itself and any affiliates or parent companies. Management should consider seeking the help of insurance consultants, attorneys, and other professionals, as necessary, to fully identify and measure the risk. Management should also review a company's financial condition or credit rating when deciding on an insurance company.

Management should understand that it cannot insure against all risks. Insurance complements, but does not replace, an effective system of controls. Thus, an overall appraisal of the control environment is important in assessing the adequacy of the insurance program.

Management can insure against risks covered in standard insurance policies. Insurance that covers physical disasters often specifically excludes computer hardware and software. To the extent that policies cover physical storage media, they generally omit the extra cost of reconstructing the recorded information found on the media. Management should clearly understand what is covered and document any gaps in coverage.

Before purchasing insurance, management should assess the costs of obtaining insurance. Estimates of these costs enable management to choose the types and amounts of insurance to carry. These estimates also allow management to determine to what extent the institution may choose to self-insure against certain losses.

Insurance policies provide a variety of coverage for events that could affect an institution's IT. The policies can be adapted to a particular institution's IT environment. The evolving threat environment is contributing to increasing interest in and purchase of insurance related to cyber risks. Insurance companies can provide coverage for items including the cost of conducting an investigation into a breach, notifying customers, reputational and crisis management, business interruption, credit monitoring for affected customers, and legal costs. Management should exercise appropriate due diligence in the review of such policies, including policy exclusions to ensure the coverage aligns with management's goals.

As part of the decision to purchase insurance, management should consider the institution's size and complexity and the level and efficacy of controls in place to mitigate risk. Types of insurance may include the following:

- **IT equipment and facilities:** Damage to the information assets and technology throughout the institution. Coverage should include leased equipment if the lessee is responsible for hazard coverage.
- **Media reconstruction:** Damage to IT media, such as magnetic tape and disks, if the institution owns and is liable for the media. Insurance is available for on-premises, off-premises, or in-transit situations. Insurance should cover the actual replacement and reproduction cost of the media or, if reproduction is not possible, the value of the media. Additional considerations to determine the amount of coverage should include programming costs and backup expense.
- **Extra expense:** The extra costs of continuing operations following damage or destruction to the institution's physical location.
- **E-banking activities:** Loss or liability arising from electronic banking activities such as Internet banking, bill payment services, and mobile financial services.
- **Business interruption:** Reimbursement for monetary losses resulting from suspension of operations because of the loss, damage, or degradation of data, systems, or services.
- **Valuable papers and records:** Cost to restore or replace papers and records (not defined as media) in case of direct physical loss or damage.
- **Errors and omissions:** Protection against claims arising from negligent acts, errors, or omissions that occur in performing IT services for others. These policies can contain the following exclusions:
 - Employee dishonesty.
 - Libel, slander, or defamation of character.
 - Liability of others assumed by the insured under contract or agreement.
 - Liability of loss or damage to property of others.
 - Personal or bodily injury or sickness.
 - Liability arising out of advice from third parties on methods, procedures, and practices, etc.
 - Liability for preparation of income tax returns.
 - Loss caused intentionally by, or at the direction of, the insured.

Once management has acquired appropriate insurance coverage, it customarily establishes procedures to review and ensure the adequacy of the coverage. These procedures should include an annual program review by the board of directors.

III.C.8 Third-Party Management

Action Summary

As part of a financial institution's third-party management program, management should ensure that third-party providers effectively provide support by doing the following:

- Negotiating clear and comprehensive contracts with appropriate terms that meet the institution's requirements.
- Ensuring receipt of audited financial statements from third-party providers at least annually.
- Reviewing results of independent audits of IT controls at third-party providers.
- Monitoring the responsiveness of third-party provider's customer service, including client user group support.

Financial institutions increasingly rely on third-party providers and software vendors. Larger or more complex institutions are more likely to have institution-wide third-party management programs that encompass all of these relationships. IT departments can contract with third-party providers for several services, including data processing, software development, equipment maintenance, business continuity, data storage, Internet access, and security management. In smaller or less complex institutions with less formal third-party management programs, the procurement of third-party services should be reviewed by institution staff familiar with the operational, financial, security, and compliance requirements for such relationships. The oversight of the relationship should be performed by staff with knowledge of the services provided.

The board of directors should hold senior management responsible for ensuring appropriate oversight of third-party relationships. Technology needed to support business objectives is often a critical factor in deciding to outsource. Managing such relationships is not just a technology issue; it is an enterprise-wide governance issue. An effective third-party management program should provide the framework for management to identify, measure, mitigate, monitor, and report risks associated with the use of third-party providers. Management should develop and implement enterprise-wide policies and procedures to govern the third-party management program, including establishing objectives and strategies, selecting a provider, negotiating the contract, and monitoring the outsourced relationship.

Management should evaluate the quality of service, control environment, and financial condition of the third parties providing the institution with critical IT services. Third parties can include financial institution affiliates, other financial institutions, and third-party service providers. As

appropriate, these third parties should support the responsibilities of their financial institution clients to adhere to all applicable laws, regulations, and supervisory guidance. Financial institution management should expect third-party support at a level consistent with the criticality of the services provided to the institution. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for more information.

When financial institution management contracts with third-party providers for some or all IT services, it should ensure that controls over outsourced activities provide the institution with the same level of assurance as controls over those activities performed in-house. Management should also consider additional oversight or controls over third-party providers that operate in foreign locations. Management should have mitigation strategies that address risks related to foreign-based third-party providers, if applicable. In the event that the financial institution locates any of its own operations offshore and develops third-party relationships at those locations, specific risk mitigation plans should be considered to address related foreign-based third-party risks.

Management should address exposures from third-party risks through an effective third-party management program. Some factors that management should consider or address include the following:

- Assessing whether each third-party relationship supports the institution's overall objectives and strategic plans.
- Evaluating prospective third-party providers based on the scope and importance of the services they provide.
- Tailoring the institution's third-party management program based on an initial and ongoing risk assessment of the institution's third parties and the services they provide.

The time and resources devoted to managing third-party relationships effectively depend on several factors, such as the critical nature of outsourced processes, staff knowledge, and complexity of systems. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for more information. Additionally, some agencies have specific guidance on third-party relationships and managing third-party relationship risk.²²

Refer to the *IT Handbook's* "Audit" booklet for more information on independent reviews of third-party providers and to the "Business Continuity Planning" booklet, appendix J, "Strengthening the Resilience of Outsourced Technology Services," for guidance focusing on cyber resilience.

²² "Third Party Risk: Guidance for Managing Third Party Risk," FDIC FIL-44-2008, June 6, 2008; OCC Bulletin 2013-29, "Third-Party Relationships: Risk Management Guidance," October 30, 2013; Federal Reserve Board Supervision and Regulation Letter 13-19 "Guidance on Managing Outsourcing Risk," December 5, 2013.

III.D Monitoring and Reporting

Action Summary

Financial institution management should ensure satisfactory monitoring and reporting of IT activities and risk. These practices should include the following:

- Developing metrics to measure performance, efficiency, and compliance with policy.
- Developing benchmarks for reviewing performance.
- Establishing and reviewing service level agreements (SLA) with critical third-party providers.
- Developing, implementing, and monitoring a process to measure IT compliance with established policies, standards, and practices.
- Evaluating the effectiveness of mitigation strategies and controls.
- Implementing a quality control or quality assurance program to monitor and test systems and applications.
- Implementing timely and effective reporting processes.

Risk monitoring provides information about the effectiveness of risk mitigation activity and should address changing threat conditions in both the financial industry and in organizations that use similar technology. Risk monitoring is ongoing within the lines of business and should include reviews of metrics (e.g., threat intelligence), performance benchmarks, SLAs, and compliance with internal policies. In addition, as part of the monitoring process, institution management should review the effectiveness of controls and ensure that quality assurance and control practices are appropriately included. Management should ensure that there is clear assignment of responsibilities and accountability for both monitoring and escalation procedures. Management should also develop an IT risk reporting process that includes defined reporting channels to ensure accurate, timely, and relevant reporting to appropriate levels of management.

III.D.1 Metrics

Metrics aid management in its ability to assess the overall IT environment. The specific metrics reported, and the frequency with which they are reported, depend on the institution's IT environment. The following are common examples:

- Number of risk issues identified for IT activities (updated regularly to reflect new or mitigated issues). This may include information gathered through the threat intelligence and collaboration process.
- Number of risk acceptance issues approved by senior management. This information may be maintained in a database or other repository of the descriptions, mitigation options, and documentation of management acceptance.

- Number of current and historical events or issues (external and internal events that deviate from the control standards).
- Number of current or outstanding (i.e., unresolved) issues identified by the business unit, internal audit, external audit, or regulator.

Many tools can be used to provide management with metrics to facilitate risk monitoring, such as key risk indicators²³ and key control indicators.²⁴ These are indicators that correlate with changes in risk and control effectiveness. When developed and monitored correctly, metrics can direct management's attention to areas of potential problems.²⁵ As appropriate, certain metrics or summary reports of metrics should be provided to the board.

III.D.2 Performance Benchmarks

Management should periodically review the institution's IT functions and determine whether plans, goals, and expectations are on target. Given the cost of and business reliance on IT functions, failure to perform such monitoring could put an institution at risk. Management should establish performance benchmarks or standards for IT functions and monitor them on a regular basis. Such monitoring can provide assurance that IT functions are meeting the defined benchmarks and can identify potential problem areas. Areas to consider include mainframe and network availability, data center availability, system reruns,²⁶ out-of-balance conditions, response time, error rates, data entry volumes, special requests, and problem reports. Management should evaluate outsourced relationships by measuring performance against SLAs.

III.D.3 Service Level Agreements

The institution should establish formal SLAs with its IT providers, including affiliates and third-party providers. Larger or more complex institutions should consider establishing SLAs for internally provided services, for example, by another division or department of the same institution. SLAs establish mutual expectations and provide a baseline for measuring IT performance. Management can tie SLAs to incentive and penalty actions. SLAs should be comprehensive to provide the institution with a high level of comfort in setting expectations. The use of performance benchmarks and outcome-based measurements could identify potential issues with attaining expectations set in the SLAs.

III.D.4 Policy Compliance

Management should develop, implement, and monitor a process to measure IT compliance with the institution's established policies. In addition to the traditional reliance on internal and third-

²³ A key risk indicator is a measure used to indicate the level of risk associated with an activity.

²⁴ A key control indicator is a metric that indicates the potential for a control to fail within an organization.

²⁵ Refer to the "Metrics" section of the *IT Handbook's* "Information Security" booklet for more information.

²⁶ A system rerun is a method of correcting an error that occurs during processing. An entire job or selection of jobs may have to be rerun to correct the error.

party audit functions, the institution should perform periodic self-assessments. The scope and frequency of self-assessments depend on the scale and historical performance of the IT function. Self-assessments provide management with an understanding of whether the institution is in compliance with the policies approved by the board.

III.D.5 Effectiveness of Controls

Control testing should include the effectiveness of control design and implementation and take into account the changing nature of the threats and the enforcement of control functions. Management should monitor risk mitigation activities and controls to ensure that identified risks are appropriately mitigated. Monitoring of the effectiveness of controls should be ongoing, and departments should provide periodic progress reports to management. Ongoing monitoring ensures that the risk management process is not a one-time or annual event.

III.D.6 Quality Assurance and Quality Control

Quality assurance (QA) is a process intended to ensure that a product or service under development meets specified requirements. Management should oversee the establishment of a QA process and update future planning with the results. QA may include internal performance measures, focus groups, and customer surveys. Management should assess whether QA testing is conducted on new or updated systems before implementation. Testing should be independent of any programming function and should incorporate user acceptance testing programs. The thorough QA testing of a new system can identify vulnerabilities or poor functionality.

Quality control (QC) is a procedure intended to ensure that a product or application adheres to a defined set of quality criteria that meet the requirements of the end user. QC includes activities that can be used to identify weaknesses or vulnerabilities in work products and to avoid the resource drain and expense of repeating a task. The traditional goal of QC activities is to ensure that a product conforms to specifications and is fit to use. QC helps to determine the following about a product:

- Whether the product works.
- Whether the product does what it is designed to do.
- Whether the product is fit for use.

QA and QC reports are valuable tools for management and help document the control process for the production environment.

III.D.7 Reporting

Management should develop an IT risk reporting process that assembles and reports IT risk information in a manner that is timely, complete, transparent, and relevant to management decisions. IT management should provide periodic reports based on risk to senior management or the board as well as to necessary stakeholders. Recipients of IT risk reports should have the authority and responsibility to act on the reported information, provide a credible challenge for information contained in the reports, and be held accountable for the outcomes. The reporting

should be appropriate to the decisions the individual reviewing the report is responsible for influencing. This reporting should be defined in accordance with the institution's enterprise-wide risk management program. Additionally, reporting should trigger appropriate, timely, and reliable escalation procedures.